INFORME DE AUDITORÍA DE SEGURIDAD WEB

Caso de estudio de portafolio — Portal de noticias (WordPress)

Objetivo	https://portal-noticias-ejemplo.com (dominio anonimizado para portafolio)
Tipo de auditoría	Prueba de penetración autorizada — caja negra
Plataforma detectada	WordPress con CDN
Autorización y alcance	Prueba realizada con autorización expresa del cliente, dentro de una ventana de pruebas acordada. Alcance limitado al dominio y subdominios indicados por el cliente; sin pruebas destructivas ni exfiltración de datos más allá de lo necesario para confirmar cada hallazgo.
Clasificación	Caso de estudio — datos identificativos y credenciales eliminados

1. Resumen Ejecutivo

Se realizó una prueba de penetración autorizada de caja negra sobre un portal de noticias basado en WordPress. Se identificaron 12 vulnerabilidades: 5 críticas, 4 altas y 3 medias. Los hallazgos más urgentes exponían información sensible del stack tecnológico y permitían acceso potencial no autorizado a la administración del sitio.

🔴 **Crítico (5)**	**Acción inmediata requerida**
🟠 **Alto (4)**	**Corregir en menos de 7 días**
🟡 **Medio (3)**	**Corregir en menos de 30 días**

2. Metodología

Técnicas de ethical hacking autorizado: escaneo de puertos y servicios, enumeración de usuarios vía REST API, análisis de plugins y temas, verificación de archivos sensibles, pruebas de inyección (XSS, SQLi) en entorno controlado, análisis de cabeceras de seguridad y enumeración de subdominios.

3. Hallazgos Críticos

Vulnerabilidades en plugin de SEO

El plugin de SEO instalado presentaba tres vulnerabilidades conocidas (CSRF en acciones administrativas, XSS en el panel y una posible inyección SQL en búsquedas). CVSS: 9.8.

XSS en plugin de caché

El plugin de caché instalado era vulnerable a Cross-Site Scripting. CVSS: 8.5.

CSRF en plugin de redirecciones

El plugin de redirecciones era vulnerable a CSRF. CVSS: 8.8.

Archivo de configuración expuesto

El archivo de configuración principal del CMS (equivalente a wp-config.php) era accesible públicamente, lo que en un entorno real expondría credenciales de base de datos y claves de seguridad del sitio. Riesgo: CRÍTICO.

Instalador del CMS expuesto

El script de instalación del CMS estaba accesible públicamente, lo cual podría permitir una reinstalación no autorizada. Riesgo: CRÍTICO.

4. Hallazgos Altos

- Usuario administrador principal expuesto vía REST API (ID y slug visibles). CVSS: 7.5.
- Clave de API de un servicio de búsqueda de terceros expuesta en el código fuente del sitio. CVSS: 7.0.
- Más de 170 usuarios expuestos vía REST API (/wp-json/wp/v2/users). CVSS: 7.5.
- Configuración de CORS permisiva. CVSS: 7.0.

5. Hallazgos Medios

- readme.html expuesto, revelando la versión del CMS.
- license.txt expuesto.
- robots.txt expuesto (informativo).

6. Evidencia Técnica (resumen)

Se confirmó un XSS reflejado mediante un parámetro de búsqueda vulnerable, verificado con un payload de prueba no destructivo en el entorno autorizado. Se identificaron los puertos 80 (HTTP) y 443 (HTTPS) abiertos; SSH y MySQL filtrados/cerrados desde el exterior.

Nota de anonimización: en la versión original de este informe se registraron credenciales de base de datos, claves de API y nombres de usuarios reales. Esos datos se eliminaron por completo de esta versión de portafolio y no deben reproducirse ni almacenarse en ningún documento compartido, incluso con autorización del cliente.

7. Recomendaciones

Inmediatas

- Actualizar los plugins de SEO, caché y redirecciones a sus últimas versiones estables.
- Ocultar el archivo de configuración y el instalador del CMS.
- Limitar el acceso a la REST API de usuarios.

Mediano plazo

- Rotar todas las claves de API expuestas.
- Implementar Content Security Policy (CSP).

- Limitar CORS a dominios específicos.
- Rotar credenciales de base de datos.

Largo plazo

- Implementar un Web Application Firewall (WAF).
- Establecer pruebas de seguridad periódicas.
- Implementar autenticación de dos factores (2FA) para administradores.

8. Conclusión

El portal presentó un perfil de riesgo crítico por la combinación de plugins vulnerables, archivos sensibles expuestos y una API REST sin restricciones adecuadas. Con las correcciones priorizadas en este informe, el riesgo se reduce significativamente; la mayoría de los hallazgos críticos son remediables en horas, no días.

— Fin del informe —